```
/bin/mkdir -m 0777 -p /var/lock
/bin/mkdir -m 0777 -p /var/log
/bin/mkdir -m 0777 -p /var/run
/bin/mkdir -m 0777 -p /var/tmp
/bin/mkdir -m 0777 -p /var/Wireless/RT2860AP
/bin/mkdir -m 0777 -p /var/tmp/wsc_upnp
cp -p /etc/SingleSKU_FCC.dat /var/Wireless/RT2860AP/SingleSKU.dat
```

Midterm Firmware Security Assessment: ThanosTech Router & Camera

A static analysis deep dive into embedded device firmware to identify critical security flaws.

Client

ThanosTech LLC

Team

Samuel LaTourette, Erek Gilbertson, Jessica Ottor

Course

COSC 6840 – Ethical Hacking Theory & Practice

Date

October 12, 2025

Objective and Scope of the Assessment

Core Objective

To perform a comprehensive static analysis of the provided device firmware to methodically uncover critical security vulnerabilities that could lead to unauthorized access or system compromise.

Static Analysis

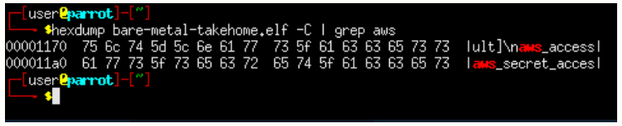
Reviewing code and binaries without executing the firmware on the hardware.

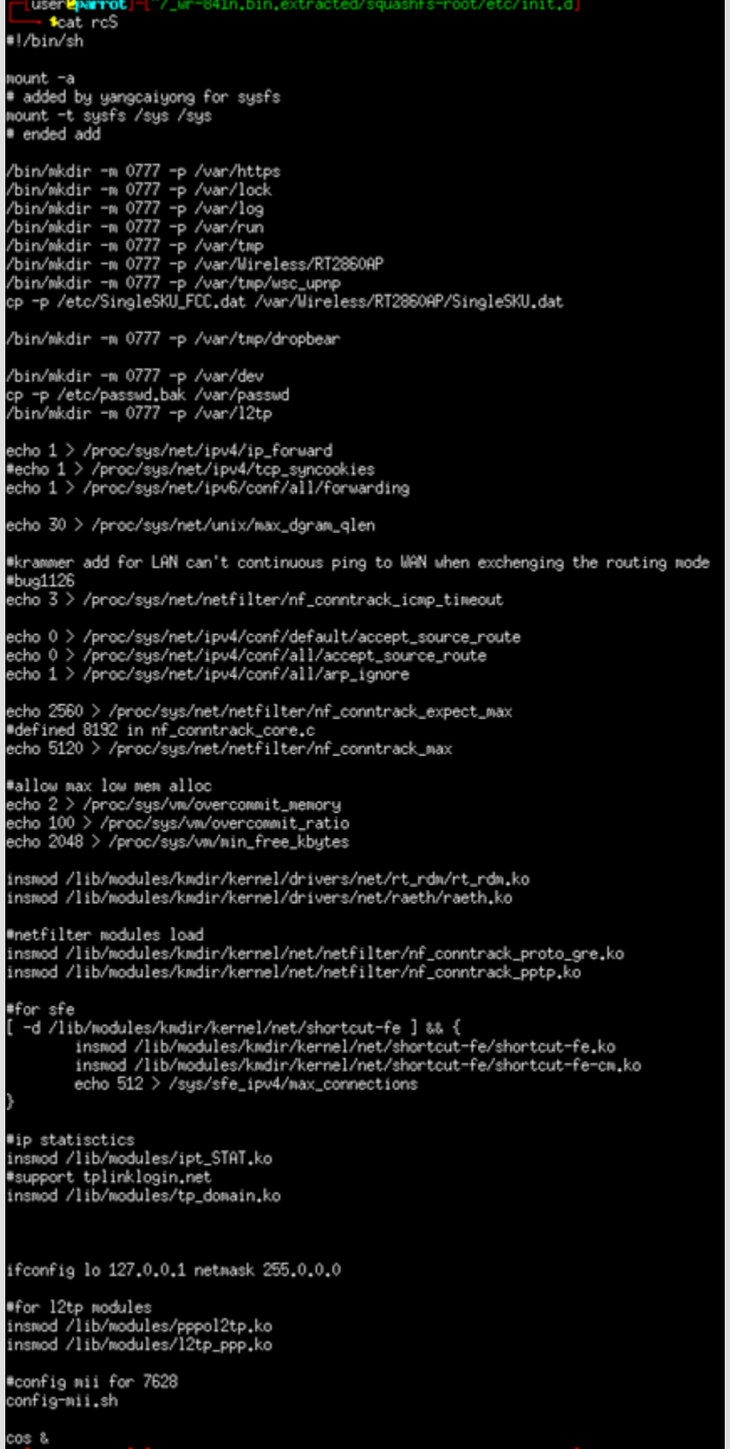
Identify Flaws

Focus on common embedded system weaknesses like hardcoded secrets and permission issues.

Analysis Scope

- **Assessment Type:** Static assessment only—no live device exploitation or network engagement was performed.
- **Firmware Targets:** TP-Link TL-WR841N (Router) and D-Link DCS-8000LH (Camera) images.
- **Key Focus Areas:** Hardcoded credentials, insecure file system permissions, outdated software components, and embedded private keys.





```
[user@parrot]-[~/_wr-841n.bin.extracted/squashfs-root/etc/init.d]
    $cat rcS
#!/bin/sh

mount -a
# added by yangcaiyong for sysfs
mount -t sysfs /sys /sys
# ended add

/bin/mkdir -m 0777 -p /var/https
/bin/mkdir -m 0777 -p /var/lock
/bin/mkdir -m 0777 -p /var/log
/bin/mkdir -m 0777 -p /var/run
/bin/mkdir -m 0777 -p /var/tmp
/bin/mkdir -m 0777 -p /var/Wireless/RT2860AP
/bin/mkdir -m 0777 -p /var/tmp/wsc_upnp
cp -p /etc/SingleSKU_FCC.dat /var/Wireless/RT2860AP/SingleSKU.dat

/bin/mkdir -m 0777 -p /var/tmp/dropbear

/bin/mkdir -m 0777 -p /var/dev
cp -p /etc/passwd.bak /var/passwd
/bin/mkdir -m 0777 -p /var/l2tp

echo 1 > /proc/sys/net/ipv4/ip_forward
#echo 1 > /proc/sys/net/ipv4/tcp_syncookies
echo 1 > /proc/sys/net/ipv6/conf/all/forwarding

echo 30 > /proc/sys/net/unix/max_dgram_qlen

#krammer add for LAN can't continuous ping to WAN when exchenging the routing mode
#bug1126
echo 3 > /proc/sys/net/netfilter/nf_conntrack_icmp_timeout

echo 0 > /proc/sys/net/ipv4/conf/default/accept_source_route
echo 0 > /proc/sys/net/ipv4/conf/all/accept_source_route
echo 1 > /proc/sys/net/ipv4/conf/all/arp_ignore

echo 2560 > /proc/sys/net/netfilter/nf_conntrack_expect_max
#defined 8192 in nf_conntrack_core.c
echo 5120 > /proc/sys/net/netfilter/nf_conntrack_max

#allow max low mem alloc
echo 2 > /proc/sys/vm/overcommit_memory
echo 100 > /proc/sys/vm/overcommit_ratio
echo 2048 > /proc/sys/vm/min_free_kbytes

insmod /lib/modules/kmdir/kernel/drivers/net/rt_rdm/rt_rdm.ko
insmod /lib/modules/kmdir/kernel/drivers/net/raeth/raeth.ko

#netfilter modules load
insmod /lib/modules/kmdir/kernel/net/netfilter/nf_conntrack_proto_gre.ko
insmod /lib/modules/kmdir/kernel/net/netfilter/nf_conntrack_pptp.ko

#for sfe
[ -d /lib/modules/kmdir/kernel/net/shortcut-fe ] && {
        insmod /lib/modules/kmdir/kernel/net/shortcut-fe/shortcut-fe.ko
        insmod /lib/modules/kmdir/kernel/net/shortcut-fe/shortcut-fe-cm.ko
        echo 512 > /sys/sfe_ipv4/max_connections
}

#ip statisctics
insmod /lib/modules/ipt_STAT.ko
#support tplinklogin.net
insmod /lib/modules/tp_domain.ko



ifconfig lo 127.0.0.1 netmask 255.0.0.0

#for l2tp modules
insmod /lib/modules/pppol2tp.ko
insmod /lib/modules/l2tp_ppp.ko

#config mii for 7628
config-mii.sh

cos &
```

OSINT and Reconnaissance

Identify device model, version, and potential public vulnerabilities before analysis.

OSINT Gathering

Conducted Open-Source Intelligence (OSINT) to gather background information on both firmware samples.

Version Verification

Verified firmware versions and vendor metadata using public repositories and manufacturer documentation.

Identified Findings

Noted specific issues: **TP-Link TL-WR841N:** Common router model with previously reported credential & BusyBox issues.**D-Link DCS-8000LH:** Known IoT camera with prior firmware exposure incidents.

Vulnerability Review

Reviewed CVE data and public exploits using NIST's National Vulnerability Database (NVD), Exploit-DB and MITRE CWE Catalog.

Strategic Focus

This phase guided focus areas for static extraction and analysis (e.g., `/etc/`, `/var/www/`, and key scripts).

Structured Methodology: From Extraction to Triage

Our process followed a systematic approach utilizing specialized open-source tools designed for embedded systems analysis.

01

Reconnaissance

Determine the underlying architecture, compression formats, and file system types embedded within the raw firmware image.

02

Extraction

Utilize **Binwalk -e** to recursively unpack the image, extracting the compressed file system (e.g., SquashFS) for deeper access.

03

Triage & Search

Use **Grep** and **Nosey Parker** to quickly locate files containing sensitive strings, configuration data, and potential secrets like API keys or credentials.

04

Deep Analysis

Review critical components such as web server configurations, startup scripts, and system file permissions (using **File** and **Hexdump**).

05

Vulnerability Cross-Reference

Link identified outdated software versions (e.g., BusyBox) to publicly disclosed Common Vulnerabilities and Exposures (CVEs).

> **Tools Used:** Binwalk, Grep, File, Hexdump, Nosey Parker

Critical Findings: TP-Link TL-WR841N Router

The analysis of the router firmware revealed multiple high-severity flaws that pose immediate risks to user security.

Hardcoded Credentials

Found in `/etc/passwd.bak` containing plain text administrator password hashes.

Risk: Full system compromise and unauthorized access (CWE-259).

Insecure Permissions

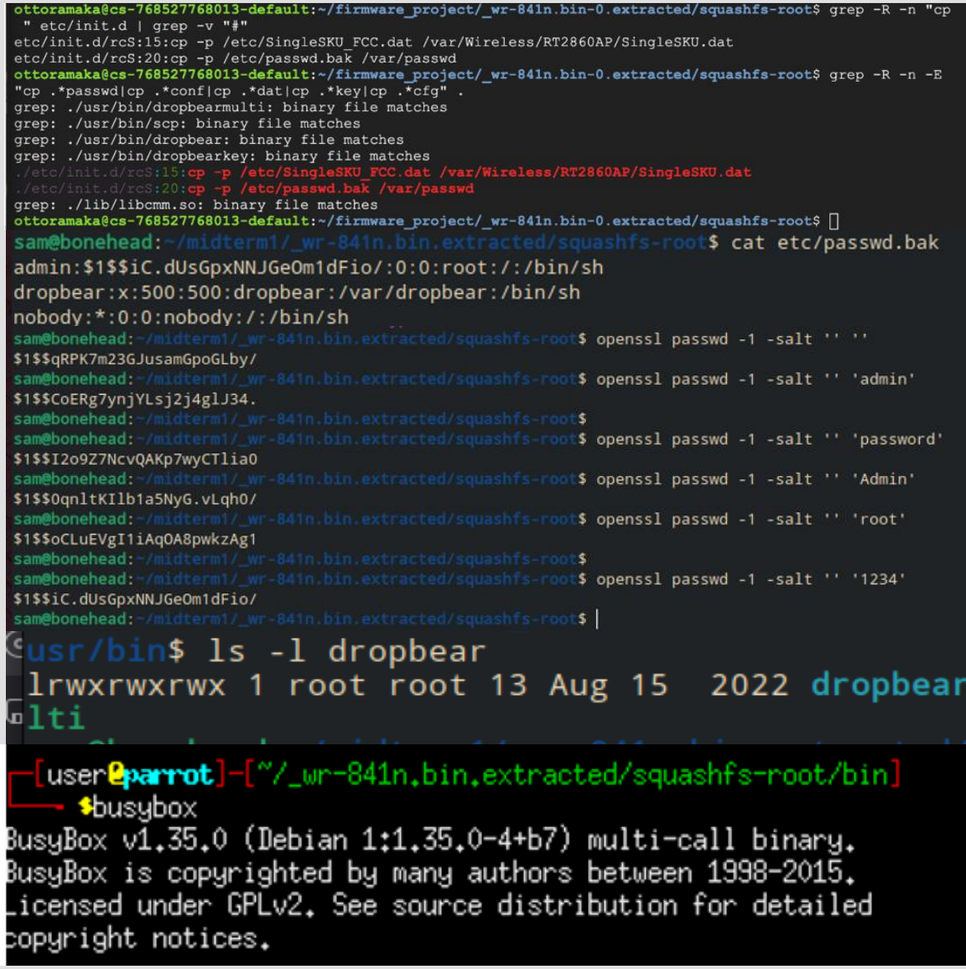
The Dropbear SSH server directory has world-writable permissions (`0777`).

Risk: Allows attackers to modify or replace authorized SSH keys (CWE-732).

Outdated Binary

The firmware uses an old version of **BusyBox v1.35.0**.

Risk: Exposed to known Remote Code Execution (RCE) and privilege escalation flaws (CVE-2022-48174).



High-Severity Flaws: D-Link DCS-8000LH Camera

The camera firmware exhibited design-level flaws related to authentication handling and credential management.

```
sam@bonehead:~/midterm17_dcs-8000lh.bin-0.extracted/squashfs-root-0/etc/db$ cat default
.xml
<?xml version="1.0"?>
<data>
<Meta>
<Version type="3" content="" />
<ETag type="4" content="635f1a123b3b9b7f19e9ab72548bf717" />
</Meta>
<System>
<Version type="3" content="1.0.0-1007" />
<OEMVersion type="3" content="1.00" />
<OEMBuild type="3" content="05" />
<Vendor type="4" content="Alphanetworks" />
<VendorUrl type="4" content="" />
<OEM type="4" content="D-Link" />
<OEMUrl type="4" content="http://www.dlink.com/" />
<Model type="3" content="DCS-8000LH" />
<ModelUrl type="4" content="http://www.dlink.com/" />
<ProdName type="4" content="Internet Camera" />
<ProdNumber type="3" content="DCS-8000LH" />
<ModelW type="3" content="DCS-8000LH" />
<ModelUrlW type="4" content="http://www.dlink.com/" />
<ProdNameW type="4" content="Wireless Internet Camera" />
<ProdNumberW type="3" content="DCS-8000LH" />
<ProdDesc type="4" content="Advenced IP Camera" />
<ProdType type="1" content="0" />
<IRCode type="2" content="2279" />
<MergeFlag type="1" content="1" />
<SettingsKey type="3" content="fa10cd9b7db.xl.e" />
<URN type="3" content="" />
</System>
```

→ Default Admin Username

Found clearly defined in `default.xml` configuration files, simplifying brute-force attacks. **(CWE-798)**

→ Exposed Auth Digest File

Temporary session tokens/auth digests are stored insecurely in `/tmp` without proper restrictions. **(CWE-377)**

→ Client-Side Password Validation

Authentication checks were observed running solely on the client-side (Javascript), which can be trivially bypassed. **(CWE-602)**

Mitigation requires shifting validation logic entirely to the server and implementing per-device unique credentials.

Automation: The Firmware Triage Script

To streamline repetitive analysis steps, an automated shell script (`fw_triage.sh`) was developed to rapidly extract and index the firmware contents.

Triage Purpose

Automates initial extraction, file system traversal, and immediate search for high-value targets using a suite of command-line tools.

Key Results

- Parses Bare-Metal Binaries using Noseyparker
- Extracts Linux-Based Binaries using Binwalk
- Finds Vulnerabilities with find command, including passwords, insecure bins and more

Usage: `bash fw_triage.sh`

```
#!/bin/bash#Check if noseyparker is installed if ! command -v noseyparker >/dev/null 2>&1; then echo "noseyparker not found, please install it first“ exit 1
fi #loop thru files in directory for file in *; do [[ -f "$file" && "$file" != *.sh ]] || continue type=$(file "$file") echo $type #file name …
```

Strategic Recommendations and Conclusion

Addressing the identified flaws requires immediate development-side intervention to prevent exploitation.

Top Mitigation Priorities

1. Remove all hardcoded credentials and enforce unique per-device passwords.
2. Secure file system permissions on critical directories, such as the Dropbear directory.
3. Immediately update legacy components, specifically BusyBox and associated libraries.
4. Implement server-side authentication checks and secure temporary file storage.

Conclusion

The static assessment revealed serious, exploitable vulnerabilities across both the ThanosTech router and camera firmware, impacting confidentiality and integrity. Integrating these security fixes into the CI/CD pipeline is essential for strengthening the company's cybersecurity posture and ensuring safer product deployments.

CVE-2022-48174 There is a stack overflow vulnerability in ash.c:6030 in busybox before 1.35. In the environment of Internet of Vehicles, this vulnerability can be executed from command to arbitrary code execution. Source: MITRE		Max CVSS EPSS Score Published Updated	9.8 0.45% 2023-08-22 2025-02-05
CVE-2022-30065 A use-after-free in Busybox 1.35-x's awk applet leads to denial of service and possibly code execution when processing a crafted awk pattern in the copyvar function. Source: MITRE	Potential exploit	Max CVSS EPSS Score Published Updated	7.8 0.60% 2022-05-18 2023-02-11
CVE-2022-28391 BusyBox through 1.35.0 allows remote attackers to execute arbitrary code if netstat is used to print a DNS PTR record's value to a VT compatible terminal. Alternatively, the attacker could choose to change the terminal's colors. Source: MITRE	Potential exploit	Max CVSS EPSS Score Published Updated	8.8 3.54% 2022-04-03 2025-06-09

References

- MITRE. (2024). Common Weakness Enumeration (CWE). Retrieved from https://cwe.mitre.org
- NIST. (2024). National Vulnerability Database (NVD). Retrieved from https://nvd.nist.gov
- Open Source Security Foundation. (2023). Secure Firmware Development Best Practices.
- Binwalk Documentation. (2024). Firmware Extraction Tool Guide.
- Offensive Security. (2024). Exploit Database (Exploit-DB). https://www.exploit-db.com
- OWASP Foundation. (2023). Firmware Security Testing Methodology (FSTM).